PROPOSAL

Governing AI use with evidence

What Morgan Stanley, Canadian banks and the Ontario public sector show, and a proposed 12-week proof of concept

[Sandeep Kanao / Sylvia Lim]

October 2026

Findings at a glance

Finding	What we saw	Source
Morgan Stanley	98% of advisor teams adopted its internal assistant (June 2024); document access rose from 20% to 80%	[4] [5]
Ontario Public Sector	Copilot Chat was the only approved tool, yet about 6% of GenAI use; no controls stopped sensitive uploads (Auditor General)	[7]
Canadian banks	Scotiabank and BMO publish principles, training and review, little on enforcement; OSFI E-23 applies from May 1, 2027	[1] [3] [6]
TTC / City Of Toronto	Microsoft Copilot is the only approved AI tool	[15]

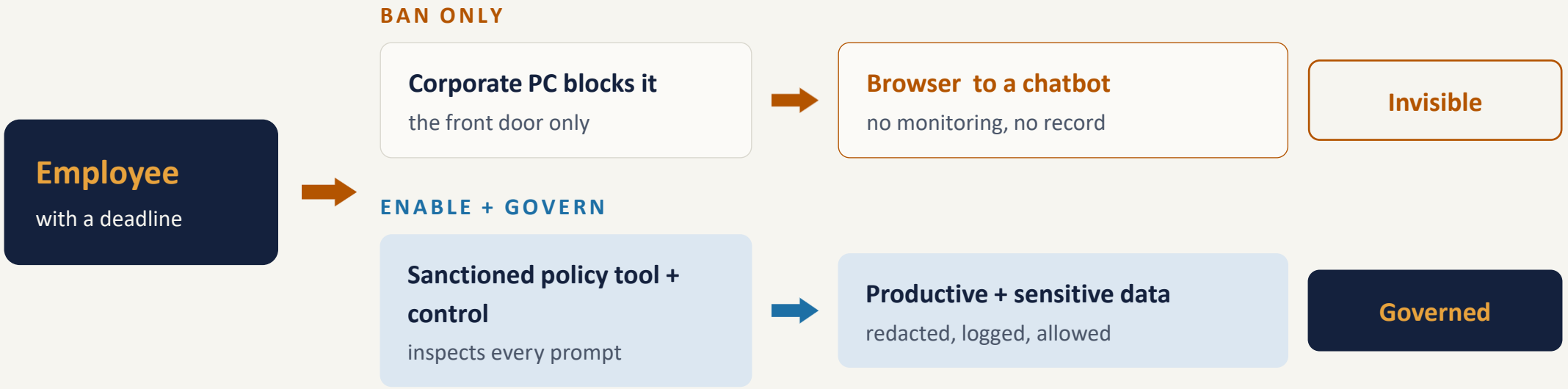
FINDINGS

What Morgan Stanley reports it did

Practice	What the firm reports	What the POC would borrow
Grounded use case	Assistant answers from the firm’s knowledge base of about 100,000 documents	Start with one narrow, bounded use case
Evaluate before scaling	Evaluation framework per use case; daily regression tests	Define evaluations and run them on every model
Human review	Advisors review summaries; recordings used with client consent	Approval step for risky requests
Data path by contract	Zero data retention arrangement with the provider	Make retention terms a go or no-go criterion
Easy approved tool	An official tool reduces use of riskier ones (vendor view)	Make the gateway the easiest path

Sources: [4] [8].

A ban hides the risk; a gateway contains it



Same employee, same task. The only difference is whether the organization can see and control the data flow.

POC design: block direct provider access at the network, send all model traffic through the gateway, inspect each prompt, write a signed receipt.

Source: [8]

LIMITATIONS

Limitations of the findings and proposal

Limitation	Why it matters	How the POC responds
A single approved tool	Ontario's auditor found most GenAI use was on unapproved sites	Tests a controlled path for other models, starting with code assistance
Findings rest on public sources	Internal practice at peers may differ	Treat as hypotheses; test in the sandbox
Morgan Stanley figures are self-reported	Adoption claims come from the firm and its supplier	Judge success by the POC's own measures
Masking will not catch everything	A sensitive value buried in text can get through	Seeded tests; sample code only; approval kept; misses reported
Evidence is not compliance	Privacy assessments, contracts and legal review remain separate	Produces evidence; legal and privacy review before production data
Self-hosted models may fall short	Open-weight models may not match hosted ones	Compare on the same tasks through the gateway

PROPOSAL

Proposal: a gateway in front of every model



Every request leaves a signed receipt: class, decision, approver, time, payload or hash.

Where the model runs changes who holds the risk, not the need to know what was sent.

PROPOSAL

Where the model runs: three options

Option	Where it runs	Pros	Cons
A. Hosted API	Vendor cloud, called through an API	Strongest models; fastest to adopt; no GPU operations	Prompts leave your network; relies on vendor contract terms
B. Canadian cloud region	Claude on Bedrock or Vertex AI (Canada)	Frontier models; choose where data is stored and processed	Still third-party infrastructure; residency is not compliance
C. Self-hosted open-weight	Your own infrastructure, such as OpenAI gpt-oss (Apache 2.0)	No prompt leaves your network; full control of logs	GPU and operations cost; you own patching and monitoring; capability must be tested; no vendor hands-on support

Claude is not offered on-premises. It runs on AWS Bedrock, Google Vertex AI and Microsoft Foundry.

Sources: [10] [11]

PROPOSAL

The 12-week proof of concept



Scope: one use case, code assistance using a stripped-down code graph, in a non-production sandbox with sample or open-source code.

Success: every POC call routed and receipted, tampering detected, policy misses reported.

Proposed timeline.

THE ASK · DECISIONS REQUESTED

Approve a 12-week proof of concept

1. Approve a time-boxed POC

12 weeks, non-production sandbox, sample or open-source code only

2. Name a sponsor and lead architect

One decision-maker and one architect for weekly checkpoints

3. Nominate reviewers

IT, security, privacy and records, each with a named contact

4. Approve access to model options

A Canadian-region hosted model and a self-hosted open-weight model, through model, through the approved review path

In return, the Senior Lead for POC development delivers a working gateway, a receipt chain an auditor can verify offline, model comparison results, and a go or no-go recommendation at week 12.

Appendix: sources

[1] OSFI, Guideline E-23 (2027), letter

[2] Shared Services Canada, CANChat

[3] Scotiabank, Scotia Intelligence (IT Brief; Fintech.ca)

[4] OpenAI, Morgan Stanley customer story (self-reported)

[5] Morgan Stanley, Debrief press release, June 2024

[6] BMO, responsible AI agent adoption blog

[7] Auditor General of Ontario, Use of AI (2026)

[8] Polygraf AI, how banks secure employee AI (vendor article; survey, Samsung and Samsung and bank figures are its claims)

[9] NBC News, JPMorgan AI assistant

[10] Anthropic, Claude regional compliance

[11] OpenAI, gpt-oss help article

[12] Treasury Board, Directive on Automated Decision-Making

[13] OMB memos M-25-21 and M-25-22 (Hunton)

[14] GSA, USAi (AI in action)

[15] City of Toronto, generative AI guidance (2025)

[16] Ontario Bill 194 overview (BABL AI)

[17] Ontario AI directive summary (regulations.ai)